CYBER & NETWORK SECURITY

When the Wrong Door Stays Unlocked

Five real cyber attacks on five real companies

Report on Different Cyber Attacks on Different Companies
Zomato · Air India · Colonial Pipeline · MGM Resorts · Capital One

STUDENT INFORMATION:

Name	Chavda Harshil
Enrollment	241105060018
Class	B
Batch	B11

REPORT OVERVIEW:

This report looks at five cyber attacks that hit real organisations: two in India and three in the United States. For each one it explains how the attackers got in, what the damage was, how the company responded, and which basic security habits might have made the incident smaller, or stopped it altogether.

KEY FOCUS:

Credential theft · Supplier compromise · Ransomware · Voice phishing · Cloud misconfiguration

Cyber & Network Security · Case Study Report

BEFORE YOU START

How to read this report

Most security reports are long lists of famous hacks. This one is deliberately smaller. It follows five incidents, and each one shows a different kind of weak spot: a stolen user database, a supplier’s servers, a forgotten password, a phone call to a help desk, and a firewall that was set up wrongly. Two of the cases are Indian and three are not. Every case gets the same three pages, so you can compare them side by side.

A NOTE ON THE CLIPPINGS

The newspaper pages are made for this report. They are styled like clippings so that each incident feels like news, but they are not scans of real newspapers, and the wording is a summary written for this file. Dates, amounts and company actions come from company statements, regulatory and court documents and press reports. Where public accounts disagree, or where only one side has spoken, the text says so.

What sits where

No.	Section	Page
1	Five ways in: the attack types behind these cases	p. 3
2	Case 1 · Zomato, 2017 (India)	p. 4
3	Case 2 · Air India and SITA, 2021 (India)	p. 7
4	Case 3 · Colonial Pipeline, 2021 (United States)	p. 10
5	Case 4 · MGM Resorts, 2023 (United States)	p. 13
6	Case 5 · Capital One, 2019 (United States)	p. 16
7	What the five cases have in common	p. 19

One habit while you read

For every case, look for the quiet gap: the stretch of time between the attackers getting in and anyone noticing. In some of these stories it was days, in others months. The expensive part of an attack is rarely the first break-in. It is the long period afterwards when an odd login or a big data transfer was happening and nobody owned the alarm.

Five ways in

The five cases look different on the surface, but each one starts from a different kind of weak point. Here are the five labels used in this report.

Attack type	What it means	Case in this report
Credential and data theft	The attacker copies stored user data, such as emails and password hashes, then sells or leaks it.	Zomato
Supplier (third-party) compromise	The target is not hit directly. A company that holds its data or runs its systems is.	Air India and SITA
Ransomware	Malware locks a company's systems and demands payment. Data is often stolen first, so there are two threats instead of one.	Colonial Pipeline
Voice phishing (vishing)	The attacker phones staff or the IT help desk with a believable story and talks their way in.	MGM Resorts
Cloud misconfiguration	A setting is wrong, such as a firewall rule or a permission that is too wide, and an outsider finds it.	Capital One

Why labels only go so far

Real incidents blur the categories. A vishing call can lead to ransomware, as it did at MGM. A supplier breach can come from stolen credentials. A leaked password can sit unnoticed in a dump for months before someone uses it, as it did at Colonial. The more useful question is practical: what did the attacker ask a person or a system to trust, and why did nothing stop it?

How an attack usually runs

1. Get in	2. Look around	3. Take or lock	4. Get noticed
A stolen password, a supplier, a call or a bad setting.	Use the access to find tools, data or admin rights.	Copy data, encrypt systems or both.	A ransom note, a news story or a stranger's tip.

WORTH REMEMBERING

None of these organisations was short of security tools. Colonial had backups, MGM had a security team, Capital One was a heavy cloud user with a mature engineering culture. What failed was a small, ordinary thing next to the tools: an account that was never switched off, a caller who was never checked, a permission that was never narrowed.

Case 1 · Zomato, May 2017

CASE 1 · INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

TECHNOLOGY · INDIA

ZOMATO CONFIRMS DATA OF 17 MILLION USERS STOLEN

Emails and hashed passwords offered for sale online; users told to reset passwords

Gurugram, May 18, 2017. Food-discovery platform Zomato has confirmed that the details of about 17 million of its users were stolen from its database. The company said the records hold email addresses and hashed passwords, and that payment information was not part of the leak. The data was reported to be on sale on a dark-web marketplace for roughly 1,000 US dollars. Zomato has reset the affected passwords and signed users out of its website and apps. It has urged anyone who uses the same password elsewhere to change it there too.

17M
user records reported stolen

Staged clipping made for this report. Figures follow Zomato's own notice and press reports from May 2017.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Zomato, restaurant discovery and food delivery platform, Gurugram, India
WHEN	Disclosed on 17 May 2017. The date of the actual theft has not been made public.
WHAT WAS TAKEN	About 17 million user records: email addresses and hashed (scrambled) passwords
WHAT WAS NOT	Zomato said payment and card details were kept separately and were not exposed
WHO NOTICED	The listing was reported by the security news site Hackread; Zomato confirmed the same day
OUTCOME	Passwords reset, users signed out, bug-bounty programme announced, listing taken down

Case 1 · Zomato

Seventeen million email addresses and password hashes ended up on a dark-web market, priced at about a thousand dollars.

What happened

In mid-May 2017 a seller using the handle nclay listed a Zomato database on a dark-web marketplace. Hackread reported the listing, and Zomato confirmed on its own blog the same day that user data had been stolen. The company put the number at about 17 million accounts, out of roughly 120 million registered users at the time. Each record had an email address and a hashed password. Zomato said payment information was stored elsewhere and was not part of the theft.

Why a hashed password still matters

A hash is a one-way scramble of a password, so a thief cannot simply read it. That is a good start, but weak or common passwords can still be guessed by running millions of tries against the hash, and plenty of people use one password on several sites. Zomato's advice to change passwords is best read as: change it everywhere you reused it.

How they got in

Zomato never published a detailed technical write-up, so how the intruder reached the database is not public. What is public is Zomato's account of the aftermath: the company said the person behind the theft told it the aim was to point out weaknesses in its security and asked it to run a proper bug-bounty programme. Zomato agreed, and the listing came down. Whether that was the whole story is impossible to check from outside. Copying and selling a database is a crime whatever the motive.

What it cost

No money was reported stolen and no payment details were involved, so the damage was mostly about trust and risk. Seventeen million email addresses make a ready-made target list for phishing, and every cracked password is a key that might fit another account.

How they responded

Zomato reset the affected passwords, signed users out of its web and mobile apps, and put out a plain-language notice on the day. It also announced a bug-bounty programme. The speed and clarity of that notice is the part of this case that holds up best.

How the path ran

1. Database copied User records are taken from Zomato's systems.	**2. Listed for sale** A seller advertises them on a dark-web market.	**3. Public notice** Zomato confirms the theft and gives a number.	**4. Reset and sign-out** Passwords reset; bug bounty promised.

Zomato, May 2017, step by step

Timeline

Date not public	Records are copied from Zomato's systems. The company has not said when or how.
17 May 2017	The listing is reported by Hackread and Zomato publishes a notice about the stolen data.
Same day	Password resets and sign-outs begin. Zomato says payment data was kept separate.
Soon after	Zomato says it spoke to the person involved and agreed to run a bug-bounty programme. The listing is removed.

Where it could have been caught

Slow, salted hashing Deliberately slow hashes such as bcrypt or Argon2 make every password guess expensive for the attacker.	**An alarm on big reads** Copying millions of rows out of a user table should trip an alert long before the copy finishes.
Fewer keys Only a handful of people and systems should be able to read the full user table, and every read should be logged.	**Invite the finders** A public disclosure or bug-bounty channel gives researchers a legitimate route in before criminals find the same gap.

TRY THIS YOURSELF
Look your own email up on haveibeenpwned.com. If it appears in an old breach, change that password, and change it on every other site where you used it.

Case 2 · Air India and SITA, 2021

CASE 2 · INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

AVIATION · INDIA

AIR INDIA CONFIRMS BREACH AFFECTING 4.5 MILLION PASSENGERS

Supplier's passenger-service system was attacked in February; airline informs customers three months later

New Delhi, May 21, 2021. Air India said on Friday that personal data of about 4.5 million passengers worldwide was exposed after a cyber attack on SITA, the company that runs its passenger service system. The records cover registrations between 26 August 2011 and 3 February 2021. They include names, dates of birth, contact details, passport details, ticket information and frequent-flyer data, as well as credit-card data. The airline said card security codes (CVV/CVC) were not held in the system, and that it has been working with SITA and outside specialists on the investigation.

4.5M
passengers affected worldwide

Staged clipping made for this report. Figures follow Air India's statement of 21 May 2021 and SITA's earlier notice.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Air India (national carrier), and SITA, the IT supplier that runs its passenger service system
WHEN	SITA servers attacked in early 2021; SITA disclosed on 4 March; Air India told passengers on 21 May 2021
WHAT WAS TAKEN	Name, date of birth, contact and passport details, ticket and frequent-flyer data, plus card data without CVV/CVC
HOW MANY	About 4.5 million passengers; data registered between 26 Aug 2011 and 3 Feb 2021
THE WEAK POINT	A third party. The attack hit the supplier, not Air India's own website
ATTRIBUTION	Security firm Group-IB later linked the activity to APT41. That is a vendor finding, not a court ruling

Case 2 · Air India / SITA

Passengers had given their passport details to an airline. The weak spot turned out to be a company most of them had never heard of.

What happened

SITA is an IT company that runs passenger service systems, the software airlines use for reservations, check-in and frequent-flyer records. In early 2021 its servers were attacked, and on 4 March 2021 SITA announced a security incident. Because SITA serves many members of the Star Alliance, one break-in reached several airlines at once. Singapore Airlines, for example, said about 580,000 of its frequent-flyer members were affected, and Malaysia Airlines also reported member data exposure.

What Air India told its passengers

On 21 May 2021 Air India confirmed that about 4.5 million people worldwide were affected. The data covered registrations from 26 August 2011 to 3 February 2021: names, dates of birth, contact details, passport details, ticket information and frequent-flyer data, along with credit-card data. The airline said the card security codes were not held in the system.

Whose problem was it?

Passengers trusted Air India. Air India trusted SITA. The attack hit the supplier, and it still became Air India's headline. That is how supply-chain risk works: a company can outsource the work, but not the responsibility.

A second layer

In June 2021 the security firm Group-IB published research suggesting the intruders had also been inside Air India's own network from around February 2021, and tied the activity to APT41, a group researchers widely describe as China-linked. That is one vendor's analysis, so it is best treated as a strong lead and not a settled fact.

What it cost

No ransom and no stolen money were reported. The harm is in what the data makes possible. A scammer who knows your name, flight and frequent-flyer number can write a very believable email, and passport details are not something a person can easily change. Passengers were told about three months after the attack, which is a long time to leave people unaware that they should be watching for scams.

How they responded

Air India said it investigated with SITA and external security specialists, worked with the card issuers, and reset the passwords of its frequent-flyer programme. Passengers were advised to change passwords and watch their card statements.

How the path ran

1. Supplier attacked SITA's passenger service servers are breached.	**2. Data copied** Records going back to 2011 are exposed.	**3. Quiet weeks** Airlines work out which customers are affected.	**4. Notice sent** Air India tells passengers on 21 May 2021.

Air India and SITA, 2021, step by step

Timeline

Early 2021	Attack on SITA's passenger service system. Airlines are informed over the following weeks.
4 Mar 2021	SITA publicly confirms a security incident.
Mar–Apr 2021	Other airlines, including Singapore Airlines and Malaysia Airlines, say their members' data was affected.
21 May 2021	Air India confirms about 4.5 million people were affected and notifies passengers.
June 2021	Group-IB links the wider campaign to APT41 and reports activity inside Air India's own network.

Where it could have been caught

Hold less data Why was registration data from 2011 still in a live system? Old data nobody needs is pure risk.	**Put the clock in the contract** Supplier agreements should require a notice within days, with enough detail for the airline to act.
Tokenise card numbers If card numbers are replaced with tokens, a stolen record contains nothing a criminal can use.	**Tell people early** A short, honest notice before every detail is known still helps customers protect themselves.

TRY THIS YOURSELF
If you get an email about a flight you did not book, do not click anything. Open the airline's own app or type its address yourself.

Case 3 · Colonial Pipeline, May 2021

CASE 3 · OUTSIDE INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

ENERGY · UNITED STATES

PIPELINE SHUT DOWN AFTER RANSOMWARE ATTACK

Colonial halts fuel flow along the US East Coast as investigators move in

Alpharetta, Georgia, May 8, 2021. Colonial Pipeline, which carries about 45 percent of the fuel used on the US East Coast, said it had halted all pipeline operations after a ransomware attack on its computer systems. The company said it took some systems offline to contain the threat, which temporarily stopped operations. It has hired an outside cybersecurity firm and contacted law enforcement and federal agencies. Colonial said it is working on a plan to restart service and will bring the pipeline back in stages when it is safe.

45%
of East Coast fuel supply affected

Staged clipping made for this report. Figures follow Colonial's statements and later US government releases.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Colonial Pipeline Company, Alpharetta, Georgia. A 5,500-mile fuel pipeline from Texas to New Jersey
WHEN	Intruder first in around 29 April 2021; ransom note and shutdown on 7 May; restart on the evening of 12 May
ENTRY POINT	The password of an old VPN account that was no longer in use and had no multi-factor authentication
GROUP	DarkSide, a ransomware-as-a-service operation
RANSOM	75 Bitcoin, about 4.4 million US dollars, paid by the company
RECOVERED	The US Justice Department announced it had recovered about 63.7 Bitcoin (roughly 2.3 million dollars) in June

Case 3 · Colonial Pipeline

One unused VPN account and one leaked password, and the main fuel pipeline of the US East Coast went quiet for five days.

What happened

On the morning of 7 May 2021 an employee in Colonial's control room saw a ransom note on a computer. The company's IT network, including its billing systems, had been locked by DarkSide ransomware. The operational systems that actually move the fuel were not reported to be affected, but Colonial shut the whole pipeline down anyway. With billing down it could not track who had received fuel, and nobody could be sure the attackers had not reached the controls.

How they got in

According to reporting at the time and the chief executive's later testimony to the US Senate, the attackers used the password of an old VPN account that nobody was using any more. It had no multi-factor authentication, and the password had reportedly turned up in a batch of leaked credentials online. Investigators from Mandiant reportedly traced the first access to 29 April, more than a week before the note appeared, and around 100 GB of data was reportedly copied out on 6 May.

The ransom

DarkSide runs a ransomware-as-a-service business: the developers build the malware and rent it to partners, who do the break-ins and share the profit. Colonial's chief executive, Joseph Blount, approved a payment of 75 Bitcoin, about 4.4 million US dollars, and described it as one of the hardest decisions of his career. He said he did not know how long recovery would take. The decryption tool the attackers supplied was reportedly slow, and the company leaned on its own backups.

What it caused

Colonial moves roughly 45 percent of the fuel used on the East Coast, so people felt it quickly. Drivers in the south-east rushed to fill up and many petrol stations ran dry. Fuel-trucking rules were relaxed under a regional emergency declaration on 9 May. The pipeline restarted on the evening of 12 May, and supply took several more days to settle.

What followed

In June the US Department of Justice said it had recovered about 63.7 Bitcoin of the ransom, worth around 2.3 million dollars by then because the price had fallen. DarkSide announced it was closing down a few days after the attack. Later in 2021 US authorities issued security directives for pipeline operators, including rules for reporting incidents.

How the path ran

1. Old VPN login Dormant account, leaked password, no MFA.	**2. Quiet week** Intruder inside from 29 April; data copied.	**3. Ransom note** IT systems encrypted on 7 May.	**4. Pipeline stopped** Shut down as a precaution; shortages follow.

Colonial Pipeline, May 2021, step by step

Timeline

29 Apr 2021	The intruder first uses the stolen VPN login, according to reporting that cited Mandiant.
6 May	Around 100 GB of data is reportedly copied out.
7 May	A ransom note appears on a control-room computer. Colonial halts pipeline operations. The ransom is paid the same day, according to later reporting.
9 May	US regional emergency declaration relaxes fuel-trucking rules.
12 May	Operations restart in the evening.
7 Jun 2021	The Justice Department announces it has recovered about 63.7 Bitcoin.

Where it could have been caught

Retire old accounts An account nobody uses is an account nobody watches. Dormant logins should be removed.	**MFA on every remote door** A password alone should never be enough to get through a VPN.
Keep IT and OT apart A billing outage should not force the pipeline itself to stop. Separation lets the business keep running.	**Practise the bad day** Test your restores, and decide in advance who can approve a shutdown, a payment or a call to the FBI.

TRY THIS YOURSELF
List every account you have not used in the last 90 days, then delete or lock each one. After that, check which of the remaining ones still have no second step on login.

Case 4 · MGM Resorts, September 2023

CASE 4 · OUTSIDE INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

BUSINESS · UNITED STATES

MGM RESORTS HIT BY CYBER ATTACK; SLOTS AND ROOM KEYS GO DOWN

Las Vegas properties run on manual systems as company shuts down networks

Las Vegas, September 12, 2023. MGM Resorts International said on Monday it had identified a cybersecurity issue affecting some of its systems, and that it took steps to protect its data, including shutting down certain systems. Guests across Las Vegas properties reported problems with digital room keys, slot machines and ATMs, and the company's website and reservation system were not working. The company said it had notified law enforcement and was working with outside experts. It did not say who was behind the attack or how it began.

$100M
estimated hit to quarterly results

Staged clipping made for this report. The cost figure comes from MGM's later filing with US regulators.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	MGM Resorts International, Las Vegas (Bellagio, MGM Grand, Aria and others)
WHEN	Systems failed from about 10–11 September 2023; company said operations were back to normal around 20 September
HOW (REPORTED)	A phone call to the IT help desk by someone posing as an employee found on LinkedIn
WHO	ALPHV (BlackCat) claimed the attack; widely linked to the group known as Scattered Spider
COST	About 100 million dollars hit to Q3 operating results plus about 10 million dollars in one-off costs, per MGM's filing
DATA	Names, contact details and dates of birth for some customers who dealt with MGM before March 2019; for some, ID numbers too

Case 4 · MGM Resorts

A phone call to an IT help desk was enough to switch off the slot machines, the room keys and the websites of one of the world's biggest casino operators.

What happened

On 11 September 2023 MGM Resorts, which runs Bellagio, MGM Grand, Aria and other properties, announced a "cybersecurity issue" and said it had shut down some systems to protect data. Guests reported that digital room keys failed, slot machines froze, ATMs stopped working and the booking website was down. Staff fell back on manual processes while the company worked to get its systems back.

How it began

ALPHV, also known as BlackCat, took credit, and the attackers were widely linked to Scattered Spider, a loose group of mostly young, English-speaking hackers. Their own account, repeated in the press, was that they found an MGM employee on LinkedIn, phoned the IT help desk pretending to be that person, and got access. MGM has not published the details, so the method is best read as reported, not confirmed. Caesars Entertainment disclosed in a filing the same week that it had been hit through a social engineering attack on an outsourced IT support vendor.

What it cost

Systems were disrupted for about ten days. In a later filing MGM estimated the attack cut its third-quarter operating results by about 100 million dollars, with roughly another 10 million in one-off costs such as consultants and legal fees. Personal data of some customers who had dealt with MGM before March 2019 was also taken, including names, contact details and dates of birth, and for some people driving-licence, Social Security or passport numbers.

How they responded

MGM shut down large parts of its own infrastructure to stop the spread, brought in outside experts and told law enforcement. It reportedly did not pay a ransom. The company said operations were back to normal around 20 September and notified affected customers.

The real lesson

Most security spending goes on firewalls and software. This attack went through a conversation. A help desk exists to help, and that is exactly what makes it attractive: the person on the other end is trained to be friendly and quick.

How the path ran

1. Call the help desk Caller poses as an employee and gets access.	**2. Climb higher** Attackers reportedly reach powerful admin accounts.	**3. Systems locked** Ransomware is deployed; MGM shuts systems down.	**4. Floors go manual** Keys, slots, ATMs and booking all stop.

MGM Resorts, September 2023, step by step

Timeline

Early Sept 2023	The reported help-desk call. The exact date has not been made public.
10–11 Sept	Guests report failing systems. MGM announces a cybersecurity issue and takes systems offline.
Mid-Sept	Caesars discloses its own social engineering incident. ALPHV claims the attack on MGM.
About 20 Sept	MGM says its operations are back to normal.
Early Oct 2023	MGM's regulatory filing puts the hit to third-quarter results at about 100 million dollars.

Where it could have been caught

Call back, always The help desk should ring the employee back on the number HR holds, before it touches a login or a reset.	**Treat resets as high risk** Resetting multi-factor authentication for an administrator should need a second person's approval.
Limit the blast radius Keep admin accounts separate from daily ones, and keep the list of people who can switch everything off short.	**Practise manual mode** Rooms, slots and tills need a rehearsed fallback so that a bad week is not a standstill.

TRY THIS YOURSELF
Next time someone phones asking for a code or a reset, hang up and call them back on a number you already have. A real colleague will not mind.

Case 5 · Capital One, 2019

CASE 5 · OUTSIDE INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

FINANCE · UNITED STATES

CAPITAL ONE: HACKER REACHED DATA OF 100 MILLION CUSTOMERS

Bank says a misconfigured firewall let an intruder reach credit card application data; suspect arrested

McLean, Va., July 30, 2019. Capital One Financial Corp. said on Monday that an outside individual gained unauthorised access to personal information of about 100 million people in the United States and about 6 million in Canada. The bank said most of the data came from credit card applications from 2005 to early 2019. Federal prosecutors in Seattle have charged Paige Thompson, a former Amazon Web Services software engineer, with computer fraud. Capital One said full credit card numbers and login credentials were not compromised, and that it fixed the configuration problem promptly.

106M
people in the US and Canada affected

Staged clipping made for this report. Figures follow Capital One's announcement and the US charging documents.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Capital One Financial Corporation, McLean, Virginia
WHEN	Intrusion in March 2019; found on 17 July 2019; announced on 29 July 2019
HOW MANY	About 100 million people in the US and about 6 million in Canada
WHAT WAS TAKEN	Application data, some credit scores, about 140,000 US SSNs and 1 million Canadian SINs
HOW	A misconfigured cloud firewall, abused through a technique called SSRF
COST	80 million dollar penalty (2020) and 190 million dollar customer settlement (2021)

Case 5 · Capital One

The bank did not lose a single customer password. It lost data on some 106 million people because a firewall in the cloud could be talked into doing something it should have refused.

What happened

In March 2019 an intruder reached a Capital One storage area in Amazon Web Services and copied a large amount of customer data. Capital One did not know until 17 July 2019, when someone emailed its responsible-disclosure address to say the data had been posted on GitHub. The bank checked, confirmed it, fixed the problem within days and contacted the FBI. It told the public on 29 July. Most of the data came from credit card applications between 2005 and early 2019, including Social Security numbers for about 140,000 US customers and about one million Canadian Social Insurance Numbers. Capital One said full card numbers and login credentials were not compromised.

How it worked

Capital One had moved much of its infrastructure to the cloud. According to the charging documents, a web application firewall on one of its servers was misconfigured. The attacker used a technique called server-side request forgery (SSRF) to make that server query the cloud's internal metadata service, which handed back temporary credentials. Those credentials belonged to a role with far more permission than it needed, so the intruder could list and copy data from storage folders. Prosecutors said data from more than 700 folders was copied. In simple terms, the front desk was tricked into handing over a master key, and the master key opened too many rooms.

The person behind it

Prosecutors in Seattle charged Paige Thompson, a former Amazon Web Services software engineer who used the online name "erratic". According to the complaint she had talked about the data in online chats and posted it where others could find it, which is what led to the tip. In 2022 she was convicted on several counts, including wire fraud and unauthorised access to computers, and was sentenced to time already served and five years of probation.

What it cost

Capital One estimated in 2019 that the incident would cost it between 100 and 150 million dollars. In August 2020 the US Office of the Comptroller of the Currency fined the bank 80 million dollars, citing weaknesses in how it managed cloud risk, and in 2021 the bank agreed a 190 million dollar settlement with affected customers. The bank said it believed the data was unlikely to have been used for fraud.

How the path ran

1. Weak firewall setting A misconfigured firewall accepts a crafted request.	**2. Credentials fetched** The server hands back a powerful cloud role.	**3. Data copied** Over 700 storage folders are read and copied.	**4. Tip received** A stranger's email leads to a fix within days.

Capital One, 2019, step by step

Timeline

22–23 Mar 2019	The intruder uses the flaw and copies data, according to the charging documents.
Spring 2019	Details are shared in online chats and files are posted to GitHub.
17 Jul 2019	A tip reaches Capital One's disclosure inbox. The hole is closed within days.
29 Jul 2019	Arrest in Seattle. Capital One announces the breach.
Aug 2020	The US OCC fines Capital One 80 million dollars.
2021–2022	Customer settlement of 190 million dollars; Thompson convicted and later sentenced.

Where it could have been caught

Least privilege A role that only needs to read one folder should not be able to list or copy every folder.	**Test the configuration** Firewall and cloud settings need regular review and scanning, not trust after the first setup.
Watch the exits Large volumes of data leaving cloud storage for an unknown address should raise an alarm within minutes.	**Make tips easy** The reason this was found at all is that someone could report it easily. Keep that channel visible.

TRY THIS YOURSELF
If you build on a cloud platform, check which roles can read all storage. For each one, ask whether it really needs to.

What the five cases have in common

None of these companies was run by careless people having a cartoonishly bad day. They were busy, and each attacker found the one door that was easy to push. The table below sets the five side by side.

Case	How they got in	What limited the damage	What was missing
Zomato, 2017	Database copied; method not published	Hashed passwords; payment data kept apart; fast notice	Alerts on bulk data reads
Air India, 2021	Supplier's servers attacked	No CVV held in the system	Less stored data; faster notice
Colonial, 2021	Old VPN password, no MFA	Backups; precautionary shutdown	MFA; clean-up of dormant accounts
MGM, 2023	Help-desk phone call	Manual fallback; reportedly no ransom paid	Call-back and identity checks
Capital One, 2019	Misconfigured firewall; over-permissive role	A tip-off channel and a fast fix	Least privilege; exit monitoring

The quiet gap, case by case

Case	Quiet gap	Measured between
Zomato	Not published	The company has not said when the data was copied.
Air India	About 3 months	From the SITA attack in early 2021 to Air India's notice on 21 May.
Colonial	About 8 days	First access on 29 April to the ransom note on 7 May.
MGM	Days (reported)	Between the help-desk call and the visible outage; exact dates not public.
Capital One	About 4 months	From the intrusion on 22–23 March to the tip on 17 July.

A short prevention list that matches these cases

- Put a second step on every remote door. A password alone should never open a VPN or an admin tool (Colonial).
- Remove what you no longer use. Dormant accounts and old data are risks with no benefit (Colonial, Air India).
- Call back on a number you already have. One habit that blunts most phone pretexts (MGM).
- Give suppliers and cloud roles the least access they need. Assume the supplier is a target too (Air India, Capital One).
- Store passwords with slow, salted hashes and keep payment data away from everything else (Zomato).
- Watch the exits. Bulk data leaving a database or storage bucket should ring a bell with a named owner (Zomato, Capital One).
- Rehearse the bad day. Test restores, manual fallbacks and public notices before you need them (Colonial, MGM).

Sources used for dates and figures include: Zomato's May 2017 security notice and Hackread's reporting; Air India's 21 May 2021 statement, SITA's March 2021 notice and Group-IB's June 2021 research; the US Justice Department release of June 2021, Colonial's statements and the CEO's June 2021 testimony to the US Senate; MGM Resorts' filings with the US SEC in September and October 2023 and Caesars Entertainment's September 2023 filing; and Capital One's 29 July 2019 announcement, the US Attorney's charging documents and the OCC's August 2020 order. Clippings in this file are illustrations, not those sources.